

## **Project Two**

William Pascoe

CYB-260: Legal and Human Factors of Cybersecurity

Gareth Marchant

April 4, 2026

## Project Two

With the approval of the partnership with Helios Health Insurance using our fitness tracking technology we should examine the how to best approach the privacy protection, data security and ethical requirements of this partnership while still maintaining our core values as a company.

Our policy concerning data privacy should be a minimized approach. We should only collect the data that is necessary to achieve our goals. We should also be very transparent in our privacy statement as to the reasons we are collecting this data and who we are sharing this data with. We need to also give the customer an option to opt out of this data collection if they choose. This approach aligns with the California Consumer Privacy Act (CCPA), which grants individuals the right to know, delete, and opt-out of the sale of their data. By us following this policy we are upholding our core value of no fine print and ensuring that we listen to the customer.

The best approach to data security is to use a zero-trust method. With the zero-trust method you never trust, no matter the source, and always verify the information. With this method we should always enforce strict access controls. We use methods like multi factor authorization, or MFA, and use a principle of least privilege. This principle ensures that everyone only has access to the data that they need access to and nothing else. We also need to make sure that the data is encrypted at all levels. Whether it is data at rest, data stored in a hard drive, or data moving around the system we need to ensure we are using the best encryption needed to prevent data breach. These procedures and others are part of the HIPAA security rule which pertains to healthcare data. By doing these actions we are also protecting our customers' data from falling into the wrong hands as well as keeping their trust in us as a company.

When we discuss the ethical side of data access, we need to consider the moral obligation of using a customer's data. Our core value is we always want to do the right thing for the customer. In doing this we need to think of the customers' data as something we use not something we necessarily own. The customer should always own their data. We emphasize that by letting them opt out of parts of the data collection or the whole thing entirely. We also need to make sure that there is a fairness about this data usage. We want to keep this as nondiscriminatory as possible. We do not ever want our outcomes of this research to appear unfairly disadvantaged to specific groups or individuals. Another ethical conclusion that we must have is accountability. If there is a data breach, we must ensure that we hold ourselves accountable to what the situation was and ensure we do the right thing for the customer, not only because the law dictates it but also to ensure we are doing right for them.

By ensuring that we practice what we say we are going to and using best practice methods we will keep our company core values when it comes to privacy protection, data security, and the ethical requirements of both our statements as well as the laws that dictate them.

**References:**

U.S. Department of Health and Human Services. (2024). *Summary of the HIPAA Security Rule*.

U.S. Department of Health and Human Services. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>

State of California Department of Justice. (2024). *California Consumer Privacy Act (CCPA)*.

State of California - Department of Justice - Office of the Attorney General.

<https://oag.ca.gov/privacy/ccpa>